

Nathaniel Abera

July 31, 2026

Information Systems Security

A. The first data protection vulnerability for FinSecure Corp. involves data in transit. The organization's Finance and HR departments share employee and payroll data using an internal FTP server that operates with legacy file-transfer protocols, which means that the data being transmitted is not secure. FTP transmits data in clear text, which exposes sensitive information as it crosses the network, including file contents and credentials. An attacker with access to the internal network could intercept the data being transferred and read employee personally identifiable information (PII) and payroll records directly. The likelihood of this occurring is high because the traffic is not encrypted by default, and the severity of this scenario is high, as it can expose employee credentials and leave the company in violation of regulatory compliance requirements.

The second data protection vulnerability for FinSecure Corp. pertains to the data at rest. The onsite Finance server maintains customer PII and financial records in a relational database that stores data in a clear text format on disk. Because no encryption is applied at the storage layer, this leaves customer PII and other sensitive information, such as financial records, at risk of being compromised. An attacker who compromises the server, or anyone with physical access to storage or backups, could read this information without needing to bypass any additional protection. This would also be a high severity scenario that could impact the organization greatly as it would expose financial data and customer PII in a fully readable form.

A cryptographic method to mitigate the risks of unencrypted file transfers is to replace the FTP server with SFTP, the SSH File Transfer Protocol. SFTP transfers files through an encrypted SSH channel. This means the credentials used to login are encrypted, and so is the employee and payroll data being transferred, before they reach the network. If the organization prefers to keep its FTP based workflow, it can deploy FTPS configured with TLS 1.3, which provides comparable protection.

The second cryptographic method for mitigating the clear text storage risk from the Finance server is to implement a Transparent Data Encryption (TDE) layer that uses the AES-256

algorithm on the relational database. TDE encrypts the database files at the storage layer, so data written to the disk and any backups are stored in an encrypted format. This protects the data being stored on the Finance server and prevents it from being readable without the decryption key.

Replacing the FTP servers with the SFTP will keep the data confidential because it is being encrypted through the SSH channel which keeps the file contents and credentials secure when they're being transmitted across the network. If an attacker intercepts the traffic using something like a packet capture tool, the attacker would still obtain the data, but it would be encrypted. This prevents an attacker from being able to read any employee PII and payroll records. The SSH protocol also includes authentication checks which are used when data is being transferred to verify that it has not been altered. If a file were to be altered during transit, the receiving system would detect the change because SFTP verifies the data, and it would not claim tampered or corrupted data as legitimate.

Adding Transparent Data Encryption with AES-256 will keep the organization's financial records and customer PII secure because data is being encrypted rather than stored in clear readable text. An attacker would not be able to read the information without the decryption key. This keeps the data protected even if the storage layer itself is exposed.

B. The first flaw in design for FinSecure Corp. is the network segmentation within the data center being absent. When the diagram is analyzed, it does not show a demilitarized zone (DMZ), and there are no other boundaries within it that separate the systems open to the public internet from the systems that hold sensitive data.

The diagram also shows that all of these systems are connected through one Network Gateway. The Web Interface, File Server, Customer Records database, Finance VMs, Accounting Systems, and the Application Server are all within the same data center segment. All of these should not be placed behind the same Gateway. The Application Server and Web Interface are public, which means they are available to the public internet. However, since they are within the same segment as the Customer Records database, this raises areas of concern because the Customer Records database contains sensitive information that should not be publicly accessible, such as financial records and customer PII.

Since there are no boundaries between these points, an attacker who compromises the publicly accessible Web Interface can move laterally through the network and gain access to the Customer Records database directly. This could expose customers' sensitive information,

including personal and financial data.

The second design flaw is that the lack of a dedicated firewall is putting the Data Center at risk. As displayed in the diagram, the Corporate Network is defended by a Firewall Router which is placed between the VPN Gateway and the internal Switch. However, no equivalent device appears anywhere in front of the Data Center.

Because of this, any traffic that enters the Data Center reaches the main business systems without being filtered or inspected. This includes malicious traffic that comes from the corporate side or the IPsec tunnel.

Since the Network Gateway is the only path into the Data Center, it also represents a single point of failure. If the gateway goes offline or fails, every system in the Data Center becomes unreachable.

The third design flaw is the use of domain administrative privileges on general user workstations. The diagram shows that the IT User Workstations have Domain Admin Access even though the tasks performed on these workstations are mostly standard and do not require that high a level of privilege.

The Domain Admin Access gives complete control over the Windows domain which gives an account the ability to reach systems throughout the environment, create accounts, and change permissions. Because these privileges are assigned to the IT User Workstations, which are also used for general tasks and email, they are exposed to the same everyday threats as any other workstation.

If an attacker compromises just one of these workstations, the attacker inherits domain administrative privileges. From there, the attacker can move through the corporate network and across the IPsec tunnel toward the Data Center. A single compromised endpoint could therefore result in the compromise of the entire domain.

FinSecure Corp. should implement network segmentation by placing the Application Server and the Web Interface in a demilitarized zone (DMZ). This will separate the Accounting Systems, the Finance VMs, and the Customer Records database from publicly accessible systems by placing a VLAN boundary or internal firewall between the tiers.

The company should also address the lack of filtering at the Data Center. They need to add a

dedicated firewall in front of the Data Center and it should be configured with least-privilege rules so that only the traffic required for business operations is permitted and all other traffic is automatically denied. The firewall should also be deployed as a high-availability pair so that a single device does not control all access to the environment. Firewalls are the standard for controlling traffic and protecting segments because they enforce network boundaries and apply pass or deny rule sets (Scarfone & Hoffman, 2009).

As for the domain admin privileges being used on general endpoints, FinSecure Corp. should focus on only giving dedicated Domain Admin Access to workstations that require it. It should not be giving high levels of access to general task focused workstations. The company should review their access privileges and implement new requirements that will both secure and harden the company's protection. Implementing things such as multifactor authentication requirements and only offering admin privileges to specific roles is a great way to minimize risk. Practicing least privilege principles like these will protect the organization from unauthorized activity (Rose et al., 2020).

The way that adding segmentation within the data center will mitigate attacks is by limiting access to sensitive data by placing the Application Server and the Web Interface within a demilitarized zone (DMZ). This prevents attackers from accessing the Customer Records database because it separates the public-facing tier from the data tier. Adding a VLAN boundary or internal firewall will also block any lateral movement between these tiers, so even if there is a breach, it will be contained at the outer tier of the network. This will improve the security of the organization by limiting the damage of any compromises made by attackers.

Adding a firewall in front of the Data Center will mitigate the lack of filtering because it inspects all traffic that enters the Data Center based on rule sets. Any malicious or unauthorized traffic will be denied before it ever reaches the Finance VMs, Customer Records database, or the Application Server. Deploying the firewall as a high-availability pair will ensure that traffic continues to be inspected even if one device fails. This improves the security of the organization by making sure all traffic into the Data Center is controlled and monitored.

Restricting Domain Admin Access to only the workstations that require it will mitigate the risk of phishing attacks. If every user on the general tasked workstations has this high a level of admin privileges, it makes the network more susceptible to attacks. Adding an additional layer of authentication, such as multifactor authentication for admin actions, or only giving admin access to the roles that require it will decrease the risk of attacks and will improve the overall security of the organization by limiting vulnerabilities.

C. The first tool that would be introduced to FinSecure Corp. would be a Security Information and Event Management (SIEM) platform that has a centralized log aggregation. Currently, the system, application, and network logs are stored on the devices where they are generated and retained for only 30 days. VPN and firewall activity is only reviewed weekly during regular maintenance hours. Endpoint antivirus alerts are not forwarded to a central console, so they remain local and require an administrator to view them individually before any action can be taken. However, an implementation of the SIEM tool would collect logs from the Data Center servers, the VPN Gateway, the Firewall Router, and any endpoint devices. This way all of the devices are put into a single platform with automated correlation and real time alerting.

The second tool that FinSecure Corp. should implement is an immutable backup environment that uses write once read many (WORM) storage, restricted access permissions, and quarterly restoration testing. Nightly backups are currently written to an offsite repository that multiple departments can access using standard storage permissions. In addition, a full restoration test is performed once each year. Implementing WORM storage would prevent stored copies from ever being altered or deleted during their retention period. Restricting permissions would separately limit access to authorized backup administrators, and doing restoration testing every quarter would also verify the recoverability far more frequently than the annual scheduled testing.

A SIEM will improve FinSecure Corp.'s detection of threats because it scans activity across multiple systems that were previously viewed separately. For example, a successful VPN login after ten failed attempts, followed by administrative activity on a Data Center server, would currently appear as unrelated entries in two different logs. The SIEM system would connect those events and raise a single alert. A SIEM will improve the organization's ability to respond promptly to any threats because it uses real time alerting that notifies administrators as any unusual activity occurs. This will reduce the delays between an attack and the action being taken against it from as much as a week to a matter of minutes. This proposal is justified because logs currently stay on the devices that generated them and are retained for only 30 days, which means that any evidence stored on these devices may be lost or altered before an attack is ever identified.

Implementing an immutable backup environment will improve FinSecure Corp.'s ability to recover from threats because backup copies are written to WORM storage. These copies cannot be altered or deleted during the retention period which makes them resistant to attacks such as ransomware. If ransomware encrypts or destroys the data, it can still be restored from a clean

backup copy the attacker was unable to modify. Quarterly restoration testing will also help ensure that recovery is working. This proposal is justified because backups are currently stored with regular permissions in a repository accessible to multiple departments, and restoration tests are performed only once each year, meaning a failed backup process could go undetected for as long as a year.

References

Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero trust architecture* (NIST Special Publication 800-207). National Institute of Standards and Technology.

<https://doi.org/10.6028/NIST.SP.800-207>

Scarfone, K., & Hoffman, P. (2009). *Guidelines on firewalls and firewall policy* (NIST Special Publication 800-41, Rev. 1). National Institute of Standards and Technology.

<https://doi.org/10.6028/NIST.SP.800-41r1>